

TSEC Risk & Cyber Advisory

tsecgrc.com | Info@tsecgrc.com

EXECUTIVE GUIDE

SOC 2 Executive Readiness Guide

TSEC Executive Guide Series | Understanding SOC 2, Readiness, Controls & Evidence

Document Version	1.0
Effective Date	September 2026
Classification	PUBLIC
Prepared by	TSEC Risk & Cyber Advisory LLC
Review Cycle	Annual

© 2026 TSEC Risk & Cyber Advisory LLC. All rights reserved. Free to distribute unmodified; not for resale.

TSEC Technical Data Sheet

Every resource published in the TSEC Compliance Library™ includes this standardized technical data sheet, summarizing the resource's identity, scope, and intended use at a glance.

Library	TSEC Executive Guide Series
Framework	AICPA Trust Services Criteria — SOC 2
Publication	Executive Guide
Category	Attestation & Assurance
Resource Name	SOC 2 Executive Readiness Guide
Document Type	Executive Guide
File Format	PDF / DOCX
Tier	Free Resource
Editable	No
Language	English
Target Audience	CEOs, CISOs, Compliance Leads, Founders
Related Frameworks	ISO/IEC 27001, NIST CSF 2.0
Approval Authority	TSEC Risk & Cyber Advisory LLC
Review Frequency	Annual
Owner	TSEC Risk & Cyber Advisory LLC
Version	1.0
Status	Published
License	TSEC Resource Library — free distribution, unmodified

Contents

TSEC Technical Data Sheet	2
Contents	3
About This Guide	4
01. SOC 2 at a Glance	4
Type I vs. Type II	4
When SOC 2 Applies.....	4
02. Trust Services Criteria.....	5
03. SOC 2 Readiness Lifecycle.....	5
Stage 1 — Scoping.....	5
Stage 2 — Gap Assessment	5
Stage 3 — Control Development	6
Stage 4 — Evidence Collection	6
Stage 5 — Audit Readiness.....	6
04. Key Control Areas	6
05. Evidence Readiness	6
06. Executive Readiness Assessment	7
07. Common Readiness Gaps	8
08. Preparing for Type I vs. Type II	8
09. TSEC SOC 2 Readiness Approach	9
Ready to Move from Readiness to Implementation?	Error! Bookmark not defined.
Revision History	9

About This Guide

This guide introduces SOC 2 in plain executive language: what it is, how readiness is built, which controls matter most, what evidence auditors expect, and where organizations most often lose time. It is written for executives and compliance leads who need to make informed decisions about scope, timeline, and investment — not as a substitute for a formal readiness assessment or an independent SOC 2 examination.

TSEC Risk & Cyber Advisory LLC is not a CPA firm and does not issue SOC 2 reports. A SOC 2 examination and report can only be issued by a licensed CPA firm. TSEC supports organizations in preparing for that examination.

01. SOC 2 at a Glance

SOC 2 (System and Organization Controls 2) is an **attestation examination**, not a certification. A licensed CPA firm evaluates an organization's controls against the AICPA Trust Services Criteria and issues an independent report. There is no pass/fail certificate and no government body involved — the report itself is the deliverable, and it is typically shared under NDA with customers and prospects who require assurance over how their data is handled.

Type I vs. Type II

Dimension	Type I Report	Type II Report
What it evaluates	Whether controls are suitably designed as of a specific date.	Whether controls are suitably designed and operated effectively across an observation period.
Time horizon	A single point in time.	An observation period established for the examination, commonly several months in duration.
Evidence required	Design documentation and a point-in-time walkthrough.	Operating evidence collected throughout the period (logs, tickets, review sign-offs, scan results).
Common use case	First-time SOC 2 programs; a faster initial deliverable for customers.	Ongoing customer and enterprise procurement requirements; the report most enterprise buyers expect.

When SOC 2 Applies

SOC 2 readiness is typically driven by customer or prospect demand rather than a legal mandate. It is most relevant to organizations that:

- Process, store, or transmit customer data on behalf of clients (SaaS, cloud, and managed service providers);
- Face security questionnaires, vendor risk reviews, or SOC 2 requirements in enterprise sales cycles;

- Operate infrastructure on AWS, Azure, GCP, or other cloud platforms in scope for customer commitments;
- Need a structured way to demonstrate security maturity to the board, investors, or insurers.

02. Trust Services Criteria

Every SOC 2 examination is scoped against one or more of the five AICPA Trust Services Criteria (TSC). The Security criterion (referred to as the **Common Criteria**) is required in every SOC 2 examination; the remaining four are included only when the organization has made a corresponding commitment to its customers.

Criteria	Category	Description	Applicability
CC	Security (Common Criteria)	Logical access, change management, risk assessment, incident response.	Required in every SOC 2 examination
A	Availability	System availability commitments, uptime SLAs, disaster recovery and business continuity.	Required if availability is committed to customers
C	Confidentiality	Protection of confidential information, including encryption and data loss prevention.	Required if confidentiality is committed to customers
PI	Processing Integrity	Complete, accurate, valid, and timely system processing.	Applicable to transaction processors
P	Privacy	Collection, use, retention, and disposal of personal information.	Required if personal data is processed

03. SOC 2 Readiness Lifecycle

SOC 2 readiness follows a predictable sequence. Skipping a stage — most commonly scoping or evidence collection — is the leading cause of delayed or incomplete audits.

Stage 1 — Scoping

Define the system boundary: which products, infrastructure, personnel, and subprocessors fall inside the examination, and which Trust Services Criteria apply based on actual customer commitments.

Stage 2 — Gap Assessment

Assess current controls against the applicable TSC, identify gaps, and produce a prioritized remediation roadmap with owners and target dates.

Stage 3 — Control Development

Build or update the policies, procedures, and technical controls needed to close identified gaps — access management, change management, vulnerability management, incident response, and vendor management chief among them.

Stage 4 — Evidence Collection

Operate the controls and systematically capture proof that they are functioning — access reviews, scan results, approval records, training completions — for the duration of the observation period (Type II) or as of the assessment date (Type I).

Stage 5 — Audit Readiness

Conduct an internal readiness review or mock walkthrough, select a qualified CPA firm, and support the examination with organized evidence and available personnel.

04. Key Control Areas

The following control areas account for the large majority of SOC 2 findings. Each should have a documented owner, a defined frequency, and evidence that demonstrates operation — not just a written policy.

- **Access Control** — role-based access, multi-factor authentication, periodic access reviews, and timely deprovisioning upon termination.
- **Change Management** — documented approval, testing, and deployment procedures for production changes.
- **Vulnerability Management** — recurring vulnerability scanning, patch management, and tracked remediation timelines.
- **Incident Response** — a documented plan, defined escalation paths, and evidence of testing or tabletop exercises.
- **Vendor Risk Management** — due diligence, contractual security requirements, and periodic reassessment of subprocessors.
- **Security Awareness** — onboarding and recurring security training with tracked completion records.
- **Monitoring & Logging** — centralized logging, alerting, and retention sufficient to support incident investigation.

05. Evidence Readiness

Documentation alone does not satisfy a SOC 2 examination. Auditors test whether controls **operated** during the review period, which means evidence must be collected continuously and consistently — not assembled retroactively in the weeks before the audit.

Evidence Category	Examples	Typical Collection Method
-------------------	----------	---------------------------

Evidence Category	Examples	Typical Collection Method
Access Control	User access lists, MFA enrollment, access review sign-offs.	GRC tool export or manual export
Change Management	Change tickets, approval records, deployment logs.	ITSM or CI/CD pipeline logs
Vulnerability Management	Scan reports, patch logs, remediation records.	Scanning tool export
Incident Response	Incident tickets, root cause analysis, resolution records.	Ticketing system
Vendor Management	Vendor assessments, contracts, BAAs, SLAs.	Procurement or legal records
Security Training	Training completion records, policy acknowledgments.	LMS or HR system
Monitoring & Logging	SIEM alerts, log retention evidence, anomaly reports.	SIEM platform

A useful discipline: evidence should be captured **as a byproduct of doing the work**, not created afterward to prove the work was done.

06. Executive Readiness Assessment

A short self-assessment for a CEO or CISO to gauge where the organization stands before engaging in a formal readiness assessment. An honest “no” or “not sure” on several of these typically indicates a multi-month readiness effort ahead of an audit.

Readiness Area	Guiding Question
Scope	Can you clearly state which systems, products, and subprocessors would fall inside a SOC 2 examination?
Access Control	Is MFA enforced for all privileged and externally accessible accounts, and are access reviews performed on a defined schedule?
Change Management	Does every production change require documented approval before deployment?
Vulnerability Management	Are vulnerability scans run on a recurring schedule with tracked remediation timelines?
Incident Response	Does a written incident response plan exist, and has it been tested in the last 12 months?
Vendor Management	Do you maintain a current inventory of vendors and subprocessors with documented risk reviews?

Readiness Area	Guiding Question
Evidence	If asked today, could you produce evidence for the last quarter proving these controls actually ran?
Ownership	Is there a named owner for the SOC 2 program with executive sponsorship?

07. Common Readiness Gaps

These gaps are common contributors to delayed readiness, audit rework, and control exceptions..

Common Gap	Why It Delays Readiness
Undefined system boundary	Scope disputes surface mid-audit, forcing rework of policies and evidence already collected.
Access reviews performed inconsistently or not at all	Auditors sample multiple periods; a single missed review period can produce a finding.
No formal vendor risk process	Subprocessors handling customer data without documented due diligence are a frequent Common Criteria gap.
Incident response plan exists but has never been tested	An untested plan cannot demonstrate operating effectiveness, only design.
Evidence collected manually and inconsistently	Gaps in evidence for even part of the observation period can invalidate a Type II claim for that control.
Change approvals bypassed under deadline pressure	Even a small number of undocumented emergency changes undermines the control across the full period.

08. Preparing for Type I vs. Type II

The choice between Type I and Type II is a business decision as much as a technical one. A Type I report demonstrates that controls are **designed** appropriately as of a given date — it can be produced faster and is often used as an initial deliverable while operating evidence accumulates. A Type II report demonstrates that those controls **operated effectively** across an observation period, and is the report most enterprise customers ultimately require.

Organizations new to SOC 2 frequently pursue a Type I report first, then transition into a Type II observation period once controls are stable — rather than attempting to produce operating evidence for controls that are still being implemented.

- **Choose Type I first** when controls are newly implemented and you need a credible interim deliverable for active sales cycles.
- **Move directly to Type II** when controls have already been operating consistently and customers require evidence of sustained operation, not just design.

- **Either path** requires the same underlying control set — the difference is the evidence window, not the controls themselves.

09. TSEC SOC 2 Readiness Approach

TSEC Risk & Cyber Advisory LLC supports organizations through each stage of the readiness lifecycle described in this guide — scoping and gap assessment, policy and control development, evidence collection workflows, and audit coordination with a qualified CPA firm. The approach is designed to produce evidence that holds up under examination, not just documentation that looks complete on paper.

Service Component	Description
Gap Assessment	Structured readiness assessment against all applicable Trust Services Criteria with prioritized findings.
Policy Development	Drafting and customization of required security policies and procedures.
Control Implementation	Hands-on support configuring technical and administrative controls.
Evidence Management	GRC tooling setup and automated evidence collection workflows.
Audit Coordination	Auditor liaison, evidence packaging, and walkthrough preparation.

From Readiness to Implementation

This guide covers the concepts and structure behind SOC 2 readiness. Turning that structure into an audit-ready program — scoped controls, populated evidence workflows, and a coordinated path to your CPA examination — is the next step.

Explore the TSEC SOC 2 Professional Pack™

A complete SOC 2 readiness kit: policies, control and evidence matrices, a gap assessment template, and audit coordination guidance built on the framework in this guide.

Info@tsecgrc.com | www.tsecgrc.com

Revision History

Version	Date	Author	Summary of Changes
1.0	September 2026	TSEC Risk & Cyber Advisory LLC	Initial publication of the Executive Guide, adapted from the SOC 2 Readiness Framework (Document SOC2-01).